SBOMs in the Era of the CRA

Madalin Neag
EU Policy Advisor@OpenSSF
The Linux Foundation
mneag@contractor.linuxfoundation.org

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Agenda

- Introduction
- CRA – establishing a Legal Requirement
- Unified Baseline
- Standards and interoperability tools
- Conclusions

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Introduction

- A follow-up blog post to the SBOM everywhere SIG WP & Blog Post
- Interoperable and actionable SBOM ecosystem
- Mechanisms contributing to that evolution
  - Regulatory frameworks
  - Open Source initiatives
- Fight against Fragmentation
- Operational tool to support security and enhance the asset management process

https://openssf.org/blog/2025/10/22/sboms-in-the-era-of-the-cra-toward-a-unified-and-actionable-framework/
by Kate Stewart, David A. Wheeler and Madalin Neag

Introduction - Accelerating Global Policy Mandates

- U.S. Executive Order 14028 in 2021, which mandated SBOMs for all federal agencies and their software vendors
  - initial NTIA (2021) Minimum Elements
- European regulatory momentum is similarly mandating SBOMs for market access, driven by the EU Cyber Resilience Act (CRA)
- Germany's BSI TR-03183-2 guideline complements the CRA
- Standards
  - ISO/IEC JTC 1/SC 27 formally standardizes and oversees the adoption of updates to ISO/IEC 5962 (SPDX)
  - OWASP and ECMA International maintain ECMA-424 (OWASP CycloneDX)
  - ETSI TR 104 034 - the "SBOM Compendium"
  - CEN 40000-1-3 (PT3) precise SBOM requirements needed to support the CRA's vulnerability handling process

MAY 12, 2021

Executive Order on Improving the Nation's Cybersecurity

Technical Guideline BSI TR-03183: Cyber Resilience Requirements for Manufacturers and Products

Part 2: Software Bill of Materials (SBOM)

CRA - establishing a Legal Requirement

- SBOM Creation – Manufacturers must prepare an SBOM in a commonly used, machine-readable format [CRA I(II)(1)], such as SPDX or CycloneD›
- Minimum Scope – The SBOM must cover at least the top-level dependencies of the product [CRA I(II)(1)]. While this is the legal minimum, including deeper transitive dependencies is strongly encouraged.
- Inclusion & Retention – The SBOM must form part of the mandatory technical documentation and be retained for at least ten years (Art.13) after the product has been placed on the market.
- Non-Publication Clause – The CRA requires the creation and availability of an SBOM but does not mandate its public disclosure Recital 77. Manufacturers must provide the SBOM upon request to market surveillance authorities or conformity assessment bodies for validation, audit, or incident investigation purposes.
- Lifecycle Maintenance – The SBOM must be kept up to date throughout the product's maintenance and update cycles, ensuring that any component change or patch is reflected in the documentation Recital 90.
- Vulnerability Handling – SBOMs provide the foundation for identifying component vulnerabilities under the CRA, while full risk assessment requires complementary context such as exploitability and remediation data. (Annex I)

2024/2847 20.11.2024

REGULATION (EU) 2024/2847 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 23 October 2024

on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

(Text with EEA relevance)

CRA Standardization request

EUROPEAN COMMISSION

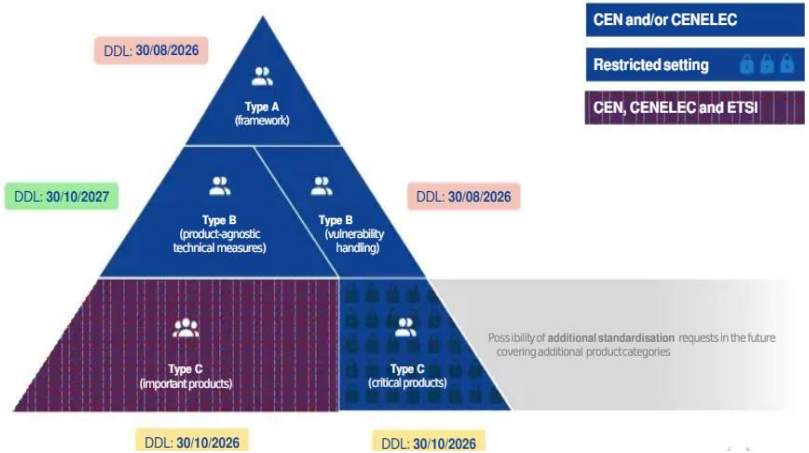
Brussels, 3.2.2025
C(2025) 618 final

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

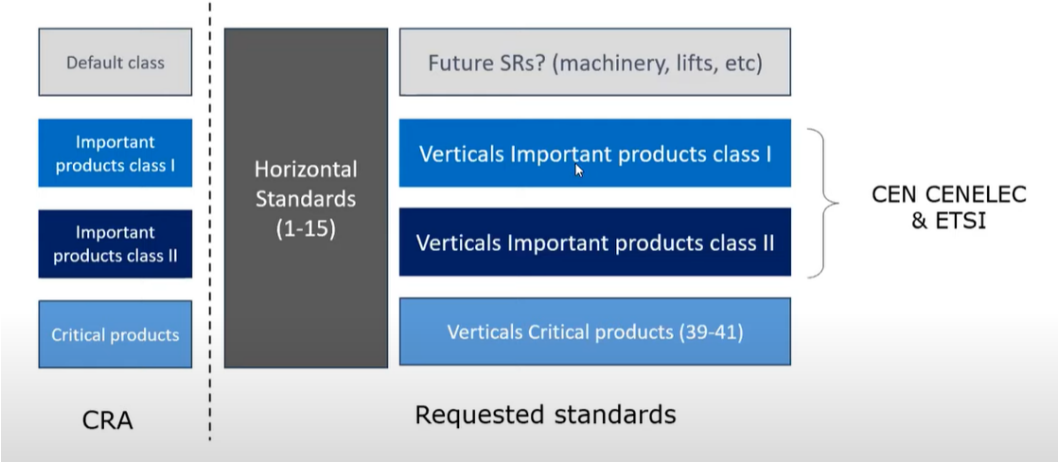
on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en
https://cyberstand.eu/sites/default/files/2025-02/Filipe%20Slides%20CRA_implementation_Feb-2025.pdf



Horizontal standards (1-15)	Vertical standards (16-41)
• Risk-based approach (CRA Annex I) • Essential Requirements (CRA Annex I part 1) • Vulnerability Handling (CRA Annex I part 2)	• Important products class 1 (CRA Annex III) • Important products class 2 (CRA Annex III) • Critical products (CRA Annex IV)

CRA Standardization request



41 topics

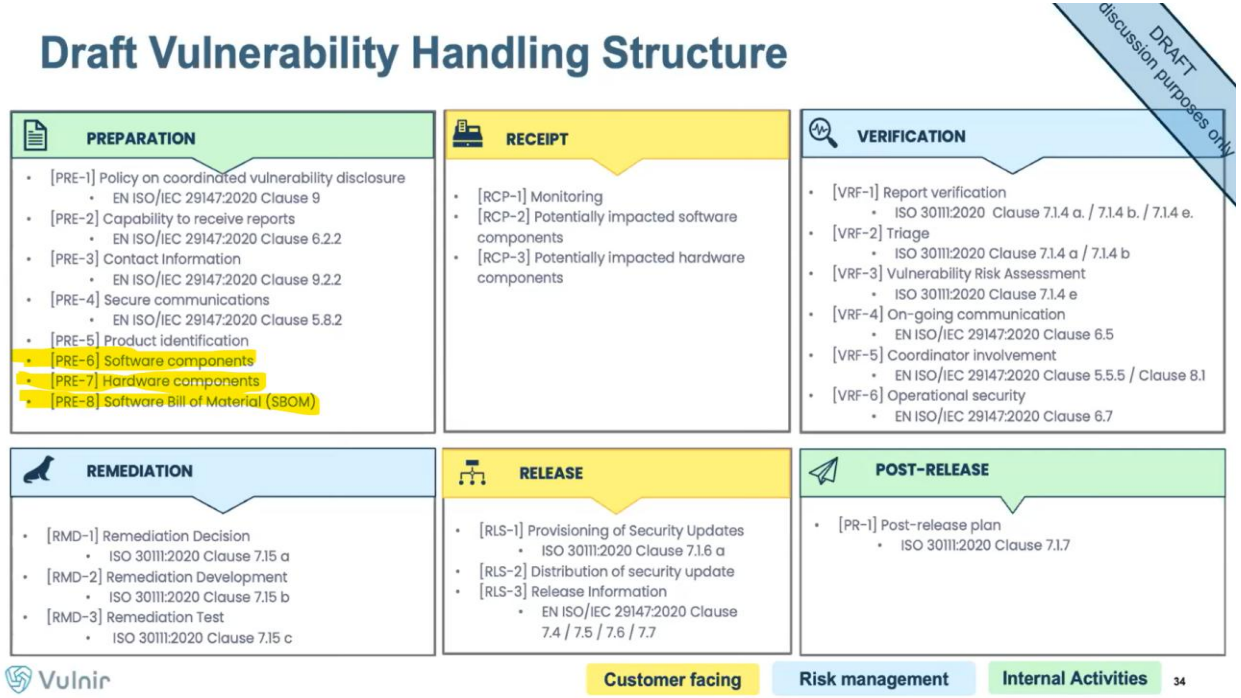
3 ‘types’ of deliverables:

Category “A”: horizontal framework	Category “B”: product-agnostic technical measures & vulnerability handling	Category “C”: Important and critical products CRA Standardization Request 9 April 2025 36
• Only CEN and CENELEC • Topic #1 (JTC 13 WG9) • deadline 2026-08-30	• Only CEN and CENELEC • Topic #2-15 (JTC 13 WG9) • Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)	• Topic #16-38: CEN, CENELEC and ETSI • deadline 2026-10-30 • Topic #39-41:CEN and CENELEC • Critical products

PT3 = 40000-1-3 = Vulnerability Handling

SBOMs as complete as possible; it is expected that manufacturers will try to record sub-components of all components

- In alignment with ISO/IEC 27036-3:2023: An SBoM should list all components in the software, including both direct and indirect (transitive) dependencies. If every dependency is known, the SBoM should explicitly state that no others exist. If some dependencies cannot be identified, it should clearly note that the list is incomplete
- Maintain SBOM up-to-date



PT1 = 40000-1-2 = Principles for cyber resilience

SBOM

- Maintenance of the Software Bill of Materials (SBOM). The SBOM lists the components used in the software, covering at least the top-level dependencies and relevant parts that qualify it for vulnerability monitoring. That entails all relevant components of an asset or a group of assets.
- Managing dependencies and third-party libraries by selecting secure libraries and keeping them up to date.
- Preparation and maintenance of an SBOM appropriate for the product

+

Third-party component cybersecurity management (due diligence)

- Third-party component cybersecurity management specifies the requirements and activities to ensure that cybersecurity risks relevant to third-party components integrated into the product are handled with due diligence and other relevant activities.
- assessing that the intended purpose and reasonably foreseeable use of the third-party component aligns with the use/integration within the product;
- monitoring for vulnerabilities in the third-party component over the product lifecycle
- securely incorporating the third-party component
- The selection of the third-party components shall be justified and documented.
- Third-party software components shall be added to the SBOM to manage dependencies

https://komport.evs.ee/Default.aspx?s=standardCommenting&doc=19694

CRA EG Guidelines

FAQ

Scope of the regulation

- When is a product in the scope of the CRA?
- What is a PDE?
- What does it mean to place a product on the market?
- Is source code a PDE?
- Does CRA applies to products placed on the market before CRA?
- Are products that are used only internally, in scope of the CRA?

Interplay with other legislations

- PLD
- RED DA
- AI Act
- GDPR
- Data Act
- Machine Regulation

Important and critical products

Manufacturer's obligations

- Risk-based approach and risk-assessment
- Vulnerability handling requirements
- Essential requirements (Annex I, part II)
- Due diligence requirements
- Support period

Reporting obligations

Substantial modification

Conformity assessment

Transition period

RDPS

Notion of 'at a distance'

'function'

Outsourced solutions

Overlap with NIS2?

Risk Assessment

CRA requirements

intended purpose, reasonably foreseeable use and reasonably foreseeable misuse

Length of time the product is expected to be in use

hEN and risk assessment

Open Source

Monetization

Stewards

New flow-chart (manufacturer vs steward)

Contributors and downstream uses

Sharing fixes upstream

Examples of scenarios

- When integrating a third party component, manufacturers may review the SBOM of that component
- In line with Article 13(5), manufacturers can integrate various types of components, including components that have not been placed on the market or that have been placed on the market before the CRA applies, provided that it exercises due diligence to ensure that the component does not compromise the cybersecurity of its own product with digital elements.
- The manufacturer does not need to bring such components into compliance with the essential requirements set out in Annex I, part I, before integrating them

https://ec.europa.eu/newsroom/dae/redirection/document/122331

Additional works

Article 13(24)

- The Commission may, by means of implementing acts taking into account European or international standards and best practices, specify the format and elements of the software bill of materials referred to in Part II, point (1), of Annex I. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 62(2).

ENISA has started a special WG to help EC with this task

- Attempt to do a State of the World SBOM study
- Help identify tooling needs and gaps
- Contribute and support defining industry best practices
- SBOM formats and tooling that are most commonly used (and why?)
- How are SBOMs used in practice to manage security and compliance
- Gap between SBOM generation and consumption
- Guide on how to ingest and normalize SBOM data
- https://ec.europa.eu/eusurvey/runner/enisa-sbom-study2025 **open until 19 December 2025**

Unified Baseline

- Ensure global compliance and maximum tool interoperability
- Stakeholders must understand the converging minimum data requirements
- A shared move toward completeness, verifiability, and interoperability
- PT3 = 40000-1-3 will have an another approach

Data Field	NTIA (U.S., 2021 Baseline)	CISA's Establishing a Common SBOM (2024)	BSI TR-03183-2 (Germany/CRA Guidance) (2024)	ETSI TR 104 034 (Compendium) (2025)
Component Name	Required	Required	Required	Required
Component Version	Required	Required	Required	Required
Supplier	Required	Required	Required	Required
Unique Identifier (e.g., PURL, CPE)	Required	Required	Required	Required
Cryptographic Hash	Recommended	Required	Required	Optional
License Information	Recommended	Required	Required	Optional
Dependency Relationship	Required	Required	Required	Required
SBOM Author	Required	Required	Required	Required
Timestamp (Date of Creation)	Required	Required	Required	Required
Tool Name / Generation Context	Not noted	Not noted	Required	Optional
Known Unknowns Declaration	Optional	Required	Optional	Optional
Common Format	Required	Not noted	Required	Required
Depth	Not noted	Not noted	Not noted	Optional

SPDX and CycloneDX

- Two major, robust, and mature open standards: SPDX and CycloneDX.
- Both provide a machine-processable format for SBOM data and support arbitrary ecosystems.
- Dual format support becomes a strategic necessity for global commerce and comprehensive security.

SPDX	CycloneDX
• maintained by The Linux Foundation • ISO/IEC 5962 • Able to provide rich, detailed metadata for compliance, provenance, legal due diligence, and supply chain risk analysis • Capturing complex license expressions, tracking component relationships in great depth • Its extensions support linkage to security advisories and vulnerability information	• Maintained by OWASP • Standardized as ECMA-424 • Able to provide a structured, machine-readable inventory of elements within an application, capturing metadata such as component versions, hierarchical dependencies, and provenance details • Supports automated generation and validation in CI/CD environments and enables early identification of vulnerabilities, outdated components, or licensing issues

OpenSSF and the Interoperability Toolkit

- Bridge global regulatory requirements with practical, open source technical solutions
- "SBOM Everywhere" Special Interest Group (SIG) connects practitioners, regulators, and standards bodies.
- Delivering interoperability and automation tooling that turns SBOM policy into practical reality
  - Protobom tackles one of the field's toughest challenges – format fragmentation.
    - It provides a format-agnostic data model capable of seamless, lossless conversion between SPDX, CycloneDX, and emerging schemas
  - BomCTL offers a powerful, developer-friendly command line utility designed for CI/CD integration.
    - It handles SBOM generation, validation, and transformation, allowing organizations to automate compliance and security workflows without sacrificing agility.
  - SBOMit manages the end-to-end SBOM lifecycle.
    - It provides built-in support for creation, secure storage, cryptographic signing, and controlled publication, embedding trust, provenance, and lifecycle integrity directly into the software supply chain process.
- SBOM Coffee Club meetings held every Monday

SBOMit

Protobom

bomctl

A Shared Vision for Action

- SBOMs have transitioned from a best practice to a requirement
- SBOMs are essential for achieving visibility, building trust, and reducing systemic risk across global digital supply chains
- promote immediate and sustained international alignment on SBOM structure and usage
- governments and industries to adopt compatible, unified systems rather than develop fragmented, country specific variants that could jeopardize scalability and interoperability
- 4 principles
  - Modular architecture
  - Trust and Provenance
  - Actionable Intelligence
  - Open Governance
- Organizations must
  - Integrate and Automate SBOMs
  - Maximize SBOM Interoperability
  - Operationalize with Open Source Software
  - Drive Shared Governance for SBOMs
  - Enable Decision-Ready Processes that build on SBOMs

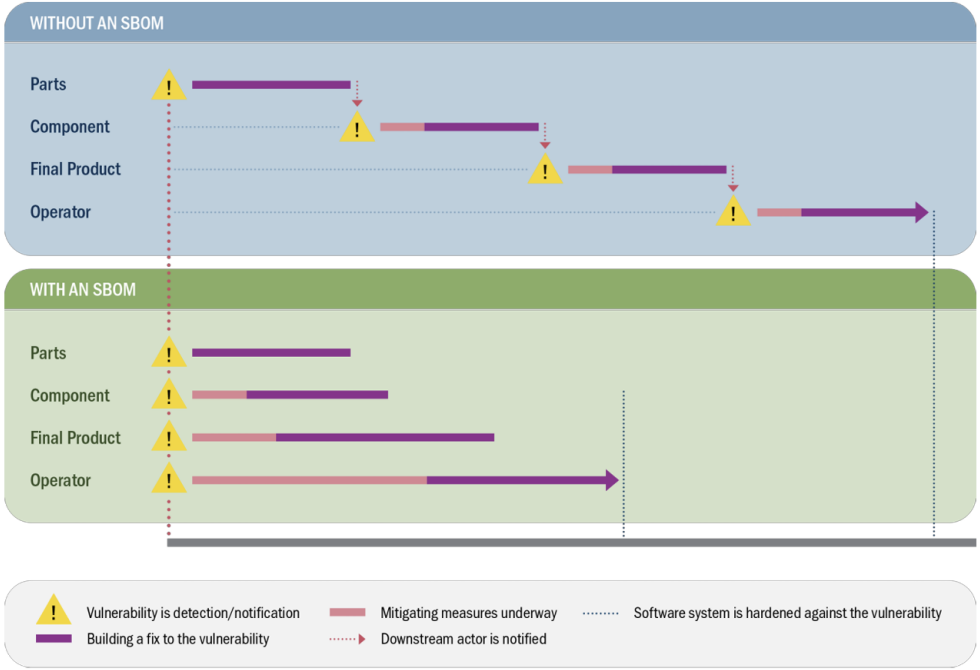


Figure 2. SBOM Reduces Total Vulnerability Response Time

A Shared Vision for Action

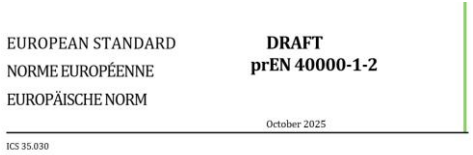
- Better software transparency will directly improve the quality of decisions made in the creation and use of software
- SBOMs must be structured, interoperable, and operationally useful for both compliance and cybersecurity
- SBOMs must be complete enough to satisfy regulatory obligations, yet structured and standardized enough to enable automation, continuous assurance, and actionable risk insight
- Eliminating format and semantic fragmentation to transform the SBOM into a universal, enforceable cybersecurity control
- Unified technical foundation that bridges legal mandates and operational realities
  - Core Schema Consensus
- Automation, lifecycle integrity, and intelligence linkage
- Connect SBOM information with vulnerability data

https://www.cisa.gov/sites/default/files/2025-09/joint-guidance-a-shared-vision-of-software-bill-of-materials-for-cybersecurity_508c.pdf

Back-up slides
Public inquiry phase for CRA-related standards

CEN PT1 and Vocabulary are under NSB ENQ

- prEN 40000-1-2 = PT1 = Part 1-2: Principles for cyber resilience https://komport.evs.ee/Default.aspx?s=standardCommenting&doc=19694
- prEN 40000-1-1 = Vocabulary https://komport.evs.ee/Default.aspx?s=standardCommenting&doc=19689
- They are also available:
  - on NBN site (National Belgium Standardization Body):
    - PT1
    - Vocabulary
  - on BSI website (UK National Standardization Body):
    - Vocabulary
    - PT1
  - And other NSB sites
  - Please note that both the BSI and NBN platforms require an account even to view the documents.
- CEN deadline to submit comments – 1st January 2026
  - National Standardization Bodies may have different deadlines
    - NBN – Dec 8
    - NEN – Dec 1
    - DIN – Dec 24
    - UK BSI – Dec 2
    - NSAI – Dec 4



EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-2

October 2025

ICS 35.030

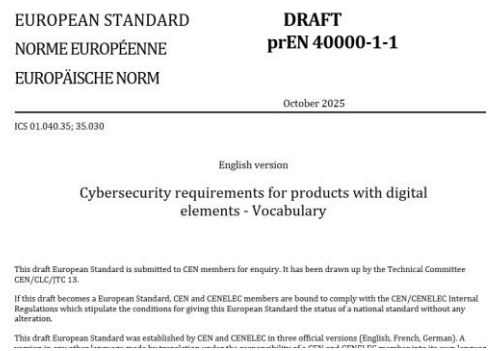
English version

Cybersecurity requirements for products with digital elements - Part 1-2: Principles for cyber resilience

Anforderungen an die Cybersicherheit von Produkten mit digitalen Bestandteilen - Grundsätze für die Cyberesilienz

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.



EUROPEAN STANDARD
NORME EUROPÉENNE
EUROPÄISCHE NORM

DRAFT
prEN 40000-1-1

October 2025

ICS 01.040.35; 35.030

English version

Cybersecurity requirements for products with digital elements - Vocabulary

This draft European Standard is submitted to CEN members for enquiry. It has been drawn up by the Technical Committee CEN/CLC/JTC 13.

If this draft becomes a European Standard, CEN and CENELEC members are bound to comply with the CEN/CENELEC Internal Regulations which stipulate the conditions for giving this European Standard the status of a national standard without any alteration.

This draft European Standard was established by CEN and CENELEC in three official versions (English, French, German). A

CEN PT2 & PT3

- PT2
  - Has resumed its activities on 2 December
  - It's the only horizontal one that will be delivered in 2027
  - Drafting will continue for two months
  - Comments resolution will last another two months
  - Public Inquiry phase is planned for 3 months in May-July 2026
- PT3
  - Delayed
  - Public inquiry planned to start on 2 December (depending on CEN/CENELEC review)
    - Deadline 1 March 2026
  - Still not clear if it will get the presumption of conformity
  - Expected to be published in October 2026

	Oct-25	Nov-25	Dec-25	Jan-26	Feb-26	Mar-26	Apr-26	May-26	Jun-26	Jul-26
Vocabulary 40000-1-1										
PT1 40000-1-2										
PT2 40000-1-4										
PT3 40000-1-3										

ETSI Open/Public Consultation

- First phase has ended on 30 November
  - After this phase, ETSI will review and assess the feedback received and implement any necessary updates.
  - Following this assessment and implementation phase, a second public consultation will be held.
  - There is no official calendar yet for the second public consultation phase
- A second phase will last until end of December
- Instructions for submitting feedback can be found in the readme.md files available with every standard. There are two official submission options:
  - Directly in the .md file or related to the .pdf files from the labs.etsi.org repositories.
  - Via an Excel template available on docbox.etsi.org.
- Important detail: I heard during the WG CYBER EUSR meetings that a deep-dive session will be held to resolve the public comments, and *only those who officially submit comments/feedback will be invited.*
- Therefore, my strong suggestion is to submit your feedback using one of the two official ETSI options listed above.
- For our internal WG consultation:
  - We have also put the available .md files into a shared Google Drive for your convenience to enable a preliminary discussion at our WG level: https://drive.google.com/drive/folders/1kg-U9KmgdjQjtC8OigdwJpwGBlBx_lHv?usp=sharing
  - We remain fully available to discuss any doubts, topics, or unclarities you may have related to these standards.
  - We will reserve time during the Standardization SIG meetings and can schedule additional meetings as needed.
- All the standards have been updated in our repository
  - You will find there the pdfs, the instructions for submitting the comments and also the Gdocs (trying to get closer to the original .md files)
  - I also added a new Template for comments
- Some of the standards are ready to be sent for HAS assessment

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
		CEN-CLC/JTC 13 WG 9	JT013095	EN 40000-1-1	Cybersecurity requirements for products with digital elements – Vocabulary
I.I	2 to 14	CEN-CLC/JTC 13 WG 9 PT1	JT013089	EN 40000-1-2:2025	Cybersecurity requirements for products with digital elements – Principles for cyber resilience
I.II	2 to 14	CEN-CLC/JTC 13 WG 9 PT3	JT013090	EN 40000-1-3	Cybersecurity requirements for products with digital elements – Vulnerability Handling
	2 to 14	CEN-CLC/JTC 13 WG 9 PT2	JT013091	EN 40000-1-4	Cybersecurity requirements for products with digital elements – Generic Security Requirements
	2 to 14	CEN-CLC/JTC 13 WG 9	JT013097	TR 40000-1-5	Cybersecurity requirements for products with digital elements – Threats and Security Objectives
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TS TTTTTTT	Guidance for the application of EN 18037 in support of the CRA
	2 to 14	CEN-CLC/JTC 13 WG 6	JT0130XX	TR TTTTTT	Documentation of the EN 18037 assessment results for the Consumer IoT market sector
III.I.1	16	CEN/TC 224 WG 17		EN TTTTTTT	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)
III.I.2	17	ETSI CYBER-EUSR	DEN/CYBER-EUS-006	EN 304 617	Essential cybersecurity requirements for browsers
III.I.3	18	ETSI CYBER-EUSR	DEN/CYBER-EUS-007	EN 304 618	Essential cybersecurity requirements for password managers
III.I.4	19	ETSI CYBER-EUSR	DEN/CYBER-EUS-0018	EN 304 619	Essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software
III.I.5	20a	ETSI CYBER-EUSR	DEN/CYBER-EUS-005	EN 304 620	Essential cybersecurity requirements for virtual private networks (VPNs)
III.I.5	20b	CLC/TC 65X WG 3	81652	EN 62443-5-XX	Security Profile for products with digital elements with the function of virtual private network (VPN)
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79830	EN IEC 62443-3-3:2019	Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	81487	EN IEC 62443-4-1:2018	Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements
III.I.5+6+7	20b+21b+22b	CLC/TC 65X WG 3	79973	EN IEC 62443-4-2:2019	Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components
III.I.6	21a	ETSI CYBER-EUSR	DEN/CYBER-EUS-009	EN 304 621	Essential cybersecurity requirements for network management systems
III.I.6	21b	CLC/TC 65X WG 3	81650	EN 62443-5-XX	Security Profile for network management systems (based on IEC 62443)
III.I.7	22a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0010	EN 304 622	Essential cybersecurity requirements for Security information and event management (SIEM) systems
III.I.7	22b	CLC/TC 65X WG 3	81654	EN 62443-5-XX	Security Profile for security information and event management (SIEM) systems (based on IEC 62443)
III.I.8	23	ETSI CYBER-EUSR	DEN/CYBER-EUS-008	EN 304 623	Essential cybersecurity requirements for boot managers

CRA Work Items

CRA	M/606 ID	Venue	Work Item	Standard reference	Standard title
III.I.9	24	ETSI CYBER-EUSR	DEN/CYBER-EUS-0015	EN 304 624	Essential cybersecurity requirements for public key infrastructure and digital certificate issuance software
III.I.10	25a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0017	EN 304 625	Essential cybersecurity requirements for physical and virtual network interfaces
III.I.10	25b	CLC/TC 65X WG 3	81651	EN 62443-5	Security Profile for physical and virtual network interfaces (based on IEC 62443)
III.I.11	26	ETSI CYBER-EUSR	DEN/CYBER-EUS-0012	EN 304 626	Essential cybersecurity requirements for operating systems
III.I.12	27a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0013	EN 304 627	Essential cybersecurity requirements for routers, modems intended for the connection to the internet, and switches
III.I.12	27b	CLC/TC 65X WG 3	81653	EN 62443-5	Security Profile for routers, modems intended for the connection to the internet, and switches (based on IEC 62443)
III.I.13+14	28, 29	CLC/TC 47X WG 1	80923	EN 50765	Essential cybersecurity requirements for microprocessors and microcontrollers with security-related functionalities
III.I.15	30	CLC/TC 47X/WG CRA		EN 50767	Essential cybersecurity requirements for application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities
III.I.16	31	ETSI CYBER-EUSR	DEN/CYBER-EUS-0011	EN 304 631	Essential cybersecurity requirements for smart home general purpose virtual assistants
III.I.17	32	ETSI CYBER-EUSR	DEN/CYBER-EUS-0014	EN 304 632	Essential cybersecurity requirements for smart home products with security functionalities, including smart door locks, security cameras, baby monitoring systems and alarm systems
III.I.18	33	ETSI CYBER-EUSR	DEN/CYBER-EUS-004	EN 304 633	Essential cybersecurity requirements for Internet connected toys covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features
III.I.19	34	ETSI CYBER-EUSR	DEN/CYBER-EUS-003	EN 304 634	Essential cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring (such as tracking) purpose and to which Regulation (EU) 2017/745 or Regulation (EU) 2017/746 do not apply or personal wearable products that are intended for the use by and for children
III.II.1	35	ETSI CYBER-EUSR	DEN/CYBER-EUS-0016	EN 304 635	Essential cybersecurity requirements for hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments
III.II.2	36a	ETSI CYBER-EUSR	DEN/CYBER-EUS-0020	EN 304 636	Essential cybersecurity requirements for firewalls, intrusion detection and/or prevention systems
III.II.2	36b	CLC/TC 65X WG 3	81649	EN 62443-5	Security Profile for firewalls and intrusion detection and prevention systems (based on IEC 62443)
III.II.3+4	37, 38	CLC/TC 47X WG 2	80924	EN 50766	Cybersecurity requirements for tamper-resistant microprocessors and microcontrollers
IV.1	39	CEN/TC 224 WG 17	002242XX	EN TTTTT	Cybersecurity requirements for Hardware Devices with Security Boxes
IV.2	40	CEN-CLC/JTC 13 WG 6	JT0130XX	EN TTTTT	Cybersecurity requirements for products with digital elements – Smart Meter Gateway
IV.3	41a	CLC/TC 47X WG 3	80922	EN 50764	Cyber Resilience of EUCC certified platforms of Smart Cards and Similar Devices Including Secure Elements
IV.3	41b	CEN/TC 224 WG 17		EN TTTTTT	Smartcards, similar devices and Secure Elements – criteria to achieve conformity with essential requirements of Regulation (EU) 2024/2847.
		ETSI CYBER-EUSR	DEN/CYBER-EUS-0019	EN 304 642	Cybersecurity Requirements for Network Functions of Telecommunications Systems

Thank you very much

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Ways to Participate

- Join a Working Group/Project
- Come to a Meeting (see Public Calendar)
- Collaborate on Slack
- Contribute on GitHub
- Become an Organizational Member
- Keep up to date by subscribing to the OpenSSF Mailing List

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.